

অধ্যায়-৩

দূর্বলতা মূল্যায়ন ও অনুপ্রবেশ পরীক্ষা

SOS

অতি সংক্ষিপ্ত প্রশ্নোত্তর :

*১। পেনেট্রেশন টেস্টিং বলতে কী বুঝায়?

উত্তর : পেনেট্রেশন টেস্টিং (Penetration Testing) বা সংক্ষেপে Pen Testing হলো কোনো একটি কম্পিউটার সিস্টেম, নেটওয়ার্ক বা ওয়েব অ্যাপ্লিকেশনের নিরাপত্তা ব্যবস্থা পরীক্ষা করার একটি অনুমোদিত ও পরিকল্পিত প্রক্রিয়া। একে অনেক সময় 'এথিক্যাল হ্যাকিং' বা 'হোয়াইট হ্যাট হ্যাকিং'-ও বলা হয়।

** ২। ওয়্যারলেস হ্যাকিং কী?

উত্তর : ওয়্যারলেস হ্যাকিং (Wireless Hacking) বলতে কোনো তারবিহীন নেটওয়ার্ক (যেমন- Wi-Fi, Bluetooth ev RFID) এর নিরাপত্তা ভেঙে সেটির তথ্য চুরি করা বা নেটওয়ার্কে অননুমোদিতভাবে প্রবেশ করাকে বোঝায়।

* ৩। কয়েকটি হ্যাকিং টুলের নাম লেখ।

উত্তর :

- i) Nmap (Network Mapper)
- ii) Wireshark
- iii) Metasploit Frameworki

- v) John the Ripper
- v) Hashcat
- vi) Burp Suite
- vii) SQLmap
- viii) Aircrack-ng ইত্যাদি।

**** ৪। লগ ফাইল বলতে কী বুঝ?**

বাকশিবো- ২০২৫

উত্তর : সাইবার নিরাপত্তা এবং কম্পিউটার সিস্টেমের ভাষায় লগ ফাইল (Log File) হলো একটি ডিজিটাল ডায়েরি বা রেকর্ডের খাতা। একটি কম্পিউটার সিস্টেম, অ্যাপ্লিকেশন বা নেটওয়ার্কে কখন কী ঘটছে, তার প্রতিটি ঘটনার বিস্তারিত বিবরণ সময়সহ এই ফাইলে স্বয়ংক্রিয়ভাবে জমা হয়।

SOS

সংক্ষিপ্ত প্রশ্নোত্তর :

*** ১। ভালনারেবিলিটি অ্যাসেসমেন্ট ও পেনেট্রেশন টেস্টিং এর মধ্যে পার্থক্য লেখ।**

বিষয়	ভালনারেবিলিটি অ্যাসেসমেন্ট	পেনেট্রেশন টেস্টিং
১. মূল উদ্দেশ্য	সিস্টেমে কোন কোন দুর্বলতা বা ছিদ্র আছে তা খুঁজে বের করা এবং একটি তালিকা তৈরি করা।	দুর্বলতাগুলো ব্যবহার করে সিস্টেমে প্রবেশ করা সম্ভব কি না বা কতটা ক্ষতি করা যায় তা পরীক্ষা করা।

২. পদ্ধতি	এটি মূলত একটি স্ক্যানিং প্রক্রিয়া, যেখানে স্বয়ংক্রিয় টুল বেশি ব্যবহৃত হয়।	এটি একটি আক্রমণাত্মক প্রক্রিয়া, যেখানে হ্যাকারদের মতো ম্যানুয়ালি আক্রমণ চালিয়ে দেখা হয়।
৩. ফলাফল	দুর্বলতাগুলোর একটি রিপোর্ট প্রদান করে যা মেরামত করা প্রয়োজন।	আক্রমণ কতটা সফল হয়েছে এবং সিস্টেমের গভীরে কতটা প্রবেশ করা গেছে তার প্রমাণসহ রিপোর্ট দেয়।
৪. সময়কাল	এটি দ্রুত সম্পন্ন করা যায় (যেমন: প্রতি সপ্তাহে বা মাসে একবার)।	এটি করতে অনেক বেশি সময়ের প্রয়োজন হয় এবং সাধারণত বছরে একবার বা বিশেষ প্রয়োজনে করা হয়।
৫. জনবল	সাধারণ আইটি কর্মীরা বিভিন্ন টুল ব্যবহার করে এটি করতে পারেন।	এটি করার জন্য দক্ষ এথিক্যাল হ্যাকার বা নিরাপত্তা বিশেষজ্ঞের প্রয়োজন হয়।

২। ওয়্যারলেস হ্যাকিং এর সাধারণ পদ্ধতিগুলো লেখ।

উত্তর : ওয়্যারলেস হ্যাকিং এর সাধারণ পদ্ধতিগুলো নিম্নে লেখা হলো :

১) পাসওয়ার্ড ক্র্যাকিং (Password Cracking) :

i) **Brute Force Attack** : হ্যাকাররা বিভিন্ন পাসওয়ার্ডের কম্বিনেশন দিয়ে বারবার চেষ্টা করে সঠিক পাসওয়ার্ড বের করার চেষ্টা করে।

ii) Dictionary Attack : একটি নির্দিষ্ট তালিকায় থাকা হাজার হাজার কমন পাসওয়ার্ড ব্যবহার করে অটোমেটেড উপায়ে পরীক্ষা করা হয়।

২) ইভিল টুইন অ্যাটাক (Evil Twin Attack) : হুবহু আসল ওয়াইফাইয়ের মতো দেখতে একটি ভুয়া বা ডামি ওয়াইফাই নেটওয়ার্ক তৈরি করা হয়। ব্যবহারকারী ভুল করে তাতে কানেক্ট করলে তার পাসওয়ার্ড হ্যাকারের কাছে চলে যায়।

৩) প্যাকেট স্নিফিং (Packet Sniffing) : বাতাসে ভেসে থাকা ডেটা প্যাকেটগুলো হ্যাকাররা বিভিন্ন টুলের সাহায্যে ইন্টারসেপ্ট বা 'শুঁকে' দেখে। এর মাধ্যমে এনক্রিপ্ট না করা তথ্য বা লগইন আইডি-পাসওয়ার্ড চুরি হতে পারে।

৪) ডাই-অথেন্টিকেশন অ্যাটাক (Deauthentication Attack) : এই পদ্ধতিতে হ্যাকার কোনো নির্দিষ্ট ডিভাইসকে তার বর্তমান ওয়াইফাই নেটওয়ার্ক থেকে বিচ্ছিন্ন করে দেয়। ডিভাইসটি যখন আবার কানেক্ট করার চেষ্টা করে, তখন হ্যাকার সেই 'Handshake' ডেটা সংগ্রহ করে পাসওয়ার্ড ক্র্যাক করার চেষ্টা করে।

৫) WPS দুর্বলতা (WPS Exploitation) : অনেক রাউটারে WPS পিন অপশন থাকে। হ্যাকাররা ৪ সংখ্যার এই পিনটি সহজেই ভেঙে রাউটারে ঢুকে পড়তে পারে।

৬) ম্যান-ইন-দ্য-মিডল (MITM) : হ্যাকারের অবস্থান হয় রাউটার এবং ব্যবহারকারীর ঠিক মাঝখানে। ফলে ব্যবহারকারী কী দেখছেন বা কী টাইপ করছেন, তার সবকিছুই হ্যাকার দেখতে পায়।

*** ৩। লগ ফাইলের ব্যবহার লেখ।

বাকাশিবো- ২০২৫

উত্তর : লগ ফাইলের ব্যবহার নিম্নে লেখা হলো :

- i) **ত্রুটি খুঁজে বের করা (Troubleshooting) :** সিস্টেম বা কোনো অ্যাপ ত্র্যাশ করলে কেন এমন হলো, তা লগ ফাইল দেখে বোঝা যায়। এতে সমস্যার মূল কারণ (Root Cause) দ্রুত শনাক্ত করা সম্ভব হয়।
- ii) **নিরাপত্তা নিশ্চিত করা (Security Monitoring) :** কোন আইডি থেকে কখন লগইন করা হয়েছে, কোনো সন্দেহজনক আইপি অ্যাড্রেস থেকে প্রবেশের চেষ্টা হয়েছে কি না—এই সব তথ্য লগ ফাইলে থাকে। এটি সাইবার আক্রমণ বা হ্যাকিং শনাক্ত করতে সাহায্য করে।
- iii) **সিস্টেম পারফরম্যান্স ট্র্যাকিং (Performance Tracking) :** সিস্টেমটি কত দ্রুত কাজ করছে বা কোথায় গিয়ে স্লো হয়ে যাচ্ছে, তা লগের মাধ্যমে পর্যবেক্ষণ করা যায়। এর ফলে সিস্টেমের কার্যক্ষমতা উন্নত করা সম্ভব হয়।
- iv) **ফরেনসিক অ্যানালাইসিস (Forensic Analysis) :** কোনো সাইবার অপরাধ সংঘটিত হওয়ার পর, হ্যাকার কোন পথে ঢুকেছিল এবং কী কী ডেটা চুরি করেছে, তা প্রমাণসহ বের করতে লগ ফাইল ব্যবহৃত হয়।
- v) **অডিটিং এবং কমপ্লায়েন্স (Auditing) :** প্রতিষ্ঠানগুলোতে কে কখন ডাটাবেজ পরিবর্তন করেছে বা সেনসিটিভ ফাইলে হাত দিয়েছে, তার একটি অফিশিয়াল রেকর্ড রাখার জন্য লগ ফাইল ব্যবহার করা হয়।

SOS**রচনামূলক প্রশ্নোত্তর :**

* ১। পেনেট্রেশন টেস্টিং এর কৌশলসমূহ বর্ণনা কর।

উত্তর : নিম্নে পেনেট্রেশন টেস্টিং এর কৌশলসমূহ বর্ণনা করা হলো :

১) **পাসওয়ার্ড আক্রমণ (Password Attack) :** পেনেট্রেশন টেস্টিং-এ পাসওয়ার্ড আক্রমণ (Password Attack) হলো এমন একটি প্রক্রিয়া যার মাধ্যমে কোনো সিস্টেম, অ্যাপ্লিকেশন বা নেটওয়ার্কের ব্যবহারকারীর পাসওয়ার্ড ভেঙে বা অনুমান করে অনধিকার প্রবেশ করার চেষ্টা করা হয়। সাইবার নিরাপত্তায় এটি অত্যন্ত গুরুত্বপূর্ণ, কারণ হ্যাকাররা প্রায়ই এই পদ্ধতি ব্যবহার করে প্রাথমিক অ্যাক্সেস পায়। যেমন : ব্রুট ফোর্স অ্যাটাক (Brute Force Attack), ডিকশনারি অ্যাটাক (Dictionary Attack), রেইনবো টেবিল অ্যাটাক (Rainbow Table Attack), ক্রেডেনশিয়াল স্টাফিং (Credential Stuffing), স্প্রেইং অ্যাটাক (Password Spraying)

২) **পেনেট্রেশন টেস্টিং-এ সোশ্যাল ইঞ্জিনিয়ারিং : (Social Engineering)** হলো এমন একটি কৌশল যেখানে কোনো কারিগরি বা সফটওয়্যার হ্যাকিংয়ের বদলে সরাসরি মানুষকে ধোঁকা দিয়ে বা মনস্তাত্ত্বিক কারসাজি (Psychological Manipulation) করে গোপন তথ্য হাতিয়ে নেওয়া হয়।

সোশ্যাল ইঞ্জিনিয়ারিংয়ের সাধারণ পদ্ধতিসমূহ :

i) ফিশিং (Phishing) : ইমেইল বা মেসেজের মাধ্যমে ভুয়া লিঙ্ক পাঠিয়ে ব্যবহারকারীর আইডি-পাসওয়ার্ড বা ক্রেডিট কার্ডের তথ্য চুরি করা। (যেমন : ব্যাংক থেকে ইমেইল আসার ভান করা)।

ii) ভিশিং (Vishing) : ফোনের মাধ্যমে ভুয়া পরিচয় দিয়ে (যেমনঃ কাস্টমার কেয়ার বা আইটি সাপোর্ট) তথ্য আদায় করা।

iii) স্মিশিং (Smishing) : এসএসএম (SMS)-এর মাধ্যমে ক্ষতিকারক লিঙ্ক পাঠিয়ে হ্যাক করা।

iv) বেইটিং (Baiting) : লোভ দেখানো। যেমন : রাস্তার ধারে একটি পেনড্রাইভ ফেলে রাখা যাতে 'বেতন লিস্ট' লেখা থাকে। কেউ কৌতূহলী হয়ে এটি তার কম্পিউটারে লাগালেই ম্যালওয়্যার ঢুকে যায়।

v) টেইলগেটিং (Tailgating) : কোনো অনুমোদিত ব্যক্তির ঠিক পেছনে পেছনে হেঁটে সিকিউরিটি গেট দিয়ে নিষিদ্ধ এলাকায় ঢুকে পড়া।

vi) প্রি-টেক্সটিং (Pretexting) : একটি সাজানো গল্প বা মিথ্যা প্রেক্ষাপট তৈরি করে বিশ্বাস অর্জন করা এবং তথ্য বের করে নেওয়া।

৩) নেটওয়ার্ক আক্রমণ (Network Attack) : পেনেট্রেশন টেস্টিং-এ নেটওয়ার্ক আক্রমণ (Network Attack) হলো এমন একটি প্রক্রিয়া যেখানে একটি প্রতিষ্ঠানের নেটওয়ার্ক অবকাঠামো (যেমনঃ রাউটার, সুইচ, সার্ভার এবং হাব) এর দুর্বলতাগুলো খুঁজে বের করে সেগুলোতে আঘাত হানা হয়। এর মূল লক্ষ্য থাকে নেটওয়ার্কের নিরাপত্তা ভেদ করে তথ্য চুরি করা বা সিস্টেমকে অচল করে দেওয়া।

নেটওয়ার্ক আক্রমণের সাধারণ পদ্ধতিসমূহ :

i) প্যাকেট স্নিফিং (Packet Sniffing) : নেটওয়ার্কের ভেতর দিয়ে যে ডেটা আদান-প্রদান হচ্ছে, তা মাঝপথে চুরি করে দেখা। হ্যাকাররা Wireshark-এর মতো টুল ব্যবহার করে এনক্রিপ্ট না করা পাসওয়ার্ড বা গোপন তথ্য দেখে ফেলে।

ii) ম্যান-ইন-দ্য-মিডল (MITM) : এখানে হ্যাকার দুই জন ব্যবহারকারীর যোগাযোগের মাঝখানে অবস্থান করে এবং উভয়ের অজান্তে তথ্য পরিবর্তন বা চুরি করে।

iii) ডস ও ডিডস অ্যাটাক (DoS DDoS) : কোনো সার্ভার বা নেটওয়ার্কে এত বেশি ফেক রিকোয়েস্ট পাঠানো হয় যে সেটি জ্যাম হয়ে যায় এবং সাধারণ ব্যবহারকারীরা সেটি ব্যবহার করতে পারে না।

iv) আইপি স্পুফিং (IP Spoofing) : হ্যাকার নিজের আসল আইপি অ্যাড্রেস লুকিয়ে একটি বিশ্বস্ত আইপি ব্যবহার করে নেটওয়ার্কে প্রবেশ করে।

v) পোর্ট স্ক্যানিং (Port Scanning) : নেটওয়ার্কের কোন কোন পোর্ট খোলা আছে তা খুঁজে বের করা। খোলা পোর্ট মানেই হ্যাকারের জন্য প্রবেশের একটি সম্ভাব্য দরজা।

**** ২। VAPT রিপোর্টের মূল বিষয়বস্তু বর্ণনা কর।**

উত্তর : একটি VAPT (Vulnerability Assessment and Penetration Testing) রিপোর্ট হলো একটি গুরুত্বপূর্ণ ডকুমেন্ট, যা প্রতিষ্ঠানের নিরাপত্তা ব্যবস্থার বর্তমান অবস্থা এবং চিহ্নিত দুর্বলতাগুলো

তুলে ধরে। এই রিপোর্টটি মূলত টেকনিক্যাল টিম এবং ম্যানেজমেন্ট-উভয় পক্ষের বোঝার উপযোগী করে তৈরি করা হয়। একটি আদর্শ VAPT রিপোর্টের মূল বিষয়বস্তুগুলো নিচে ধারাবাহিকভাবে বর্ণনা করা হলোঃ

১. এক্সিকিউটিভ সামারি (Executive Summary) : এটি রিপোর্টের সবচেয়ে গুরুত্বপূর্ণ অংশ, যা মূলত অ-কারিগরি বা ম্যানেজমেন্ট পর্যায়ের ব্যক্তিদের জন্য লেখা হয়। এতে গ্রাফ বা চার্টের মাধ্যমে সিস্টেমের সামগ্রিক নিরাপত্তা অবস্থা দেখানো হয়। প্রধান ঝুঁকিগুলো কী কী এবং সেগুলো ব্যবসার ওপর কী প্রভাব ফেলতে পারে, তার একটি সংক্ষিপ্ত সারসংক্ষেপ থাকে।

২. স্কোপ অব ওয়ার্ক (Scope of Work) :

এখানে উল্লেখ থাকে যে ঠিক কোন কোন সিস্টেমের ওপর পরীক্ষা চালানো হয়েছে। যেমনঃ নির্দিষ্ট আইপি অ্যাড্রেস, ডোমেইন নাম, মোবাইল অ্যাপ বা নেটওয়ার্ক রেঞ্জ।

৩. মেথডোলজি (Methodology) : টেস্টটি করার সময় কোন আন্তর্জাতিক স্ট্যান্ডার্ড বা পদ্ধতি অনুসরণ করা হয়েছে তা এখানে থাকে। যেমনঃ OWASP (ওয়েব অ্যাপ্লিকেশনের জন্য), OSSTMM বা NIST ফ্রেমওয়ার্ক।

৪. ভালনারেবিলিটি ডিটেইলস (Vulnerability Details) : এটি রিপোর্টের মূল অংশ যেখানে প্রতিটি দুর্বলতার বিস্তারিত থাকে। প্রতিটি দুর্বলতার জন্য নিচের তথ্যগুলো দেওয়া হয় :

i) **রিস্ক রেটিং (Risk Rating)** : দুর্বলতাটি কতটা ভয়াবহ (Critical, High, Medium, Low) ।

ii) **প্রফ অব কনসেপ্ট (PoC)** : হ্যাকার কীভাবে এই দুর্বলতা কাজে লাগিয়ে আক্রমণ করেছে, তার স্ক্রিনশট বা প্রমাণ ।

iii) **প্রভাব (Impact)** : এই দুর্বলতার কারণে কী কী ক্ষতি হতে পারে (যেমনঃ ডেটা চুরি বা সার্ভার ডাউন) ।

৫. **রেমেডিয়েশন বা সমাধান**

(Remediation/Recommendations) : শুধুমাত্র সমস্যা নয়, বরং সেগুলো কীভাবে সমাধান করতে হবে তার বিস্তারিত গাইডলাইন এখানে দেওয়া থাকে । এটি ডেভেলপার বা আইটি অ্যাডমিনদের কাজ সহজ করে দেয় ।

৬. **কনক্লুশন (Conclusion)** : পুরো প্রক্রিয়ার একটি চূড়ান্ত সিদ্ধান্ত এবং ভবিষ্যতে নিরাপত্তা বজায় রাখার জন্য কিছু পরামর্শ দেওয়া হয় ।